



Implementación y seguimiento de controles de seguridad de la información

Breve descripción:

Este componente formativo profundiza en la aplicación práctica de los controles de seguridad de la información como parte esencial de la gestión organizacional. A través del estudio de su propósito, tipología, normativa y relación con los activos y riesgos, el aprendiz comprenderá cómo seleccionar e implementar controles adecuados. Asimismo, se enfatiza en los criterios de priorización, la definición de responsables y la importancia del monitoreo continuo, fomentando la capacidad de establecer medidas preventivas y correctivas que garanticen la protección integral de la información y la resiliencia de la organización frente a incidentes.

Diciembre 2025

Contenido

Introducción.....	1
1. Controles de seguridad de la información.....	4
1.1 Propósito de los controles de seguridad de la información	5
1.2 Tipos de controles	6
1.3 Normativa legal.....	13
1.4 Relación con activos y riesgos	16
1.5 Criterios de selección	17
2. Implementación de controles.....	20
2.1 Criterio de priorización	20
2.2 Proceso de implementación de controles	22
2.3 Roles y responsabilidades en seguridad de la información	24
3. Monitoreo y verificación.....	28
3.1 Importancia de la supervisión y validación de la seguridad de la información	28
3.2 Estrategias de seguimiento.....	29
3.3 Periodicidad	31
3.4 Registros y evidencias.....	32
Síntesis.....	36

Material complementario.....	38
Glosario.....	39
Referencias bibliográficas.....	42
Créditos.....	44

Introducción

En un entorno donde las amenazas digitales evolucionan de manera constante, los controles de seguridad de la información se consolidan como herramientas fundamentales para mitigar riesgos, proteger los activos y garantizar la continuidad de las operaciones. Más allá de la identificación de vulnerabilidades, las organizaciones deben implementar medidas concretas que aseguren la confidencialidad, integridad y disponibilidad de la información, fortaleciendo la confianza tanto interna como externa.

El presente componente formativo tiene como propósito brindar a los aprendices los conocimientos y habilidades necesarias para comprender el propósito, los tipos y la función de los controles de seguridad, así como su relación con los activos y los riesgos previamente identificados. Asimismo, se abordarán los procesos de selección, implementación y priorización de controles, junto con el rol de los responsables en su gestión, promoviendo un enfoque integral y proactivo.

La formación se desarrollará mediante experiencias prácticas, ejercicios de priorización y simulaciones de aplicación de controles, complementadas con estrategias de monitoreo, verificación y registro de evidencias. De este modo, los aprendices podrán transferir los conocimientos adquiridos a contextos reales, contribuyendo activamente al fortalecimiento de la seguridad de la información en sus entornos productivos.

Video 1. Implementación y seguimiento de controles de seguridad de la información



[Enlace de reproducción del video](#)

Síntesis del video: Implementación y seguimiento de controles de seguridad de la información

En un entorno digital donde los riesgos evolucionan de forma constante, las organizaciones enfrentan desafíos crecientes para proteger su información. En este escenario, los controles de seguridad se convierten en la primera línea de defensa para resguardar los activos y garantizar la continuidad de los procesos organizacionales. Este componente formativo invita a explorar sobre la importancia de seleccionar, implementar y mantener controles de seguridad eficaces, comprendiendo su relación directa con los riesgos previamente identificados y su papel esencial dentro de la gestión integral de la seguridad. A lo largo del contenido, los aprendices conocerán la clasificación de los controles de seguridad y aprenderán a

establecer criterios de priorización según la criticidad de los activos y el nivel de exposición al riesgo, fortaleciendo así la toma de decisiones basada en la gestión del riesgo. Se abordará el papel de los responsables en la implementación de los controles, la necesidad de documentar y comunicar las políticas, y la importancia del monitoreo y la mejora continua como factores clave para mantener la eficacia y sostenibilidad de las medidas adoptadas.

1. Controles de seguridad de la información

Los controles de seguridad son elementos esenciales para proteger los datos y las infraestructuras críticas de una organización. Estos controles incluyen todas las medidas y contramedidas diseñadas para prevenir, detectar, mitigar y neutralizar los riesgos que puedan afectar la información, los sistemas informáticos, los equipos físicos u otros activos de la empresa.

En la actualidad, el aumento de los ciberataques y la creciente complejidad de las amenazas digitales hacen que la implementación de controles de seguridad ya no sea una opción, sino una necesidad estratégica. Su aplicación permite no solo proteger los recursos organizacionales, sino también cumplir con las leyes y regulaciones sobre privacidad de datos, evitando sanciones o consecuencias legales significativas (IBM, 2023).

De manera sencilla, los controles de seguridad son acciones y mecanismos que ayudan a reducir los riesgos a niveles aceptables. Esto se logra mediante el uso de procedimientos, tecnologías y buenas prácticas que garantizan las tres propiedades fundamentales de la información:

- **Confidencialidad:** solo las personas autorizadas pueden acceder a la información.
- **Integridad:** los datos se mantienen correctos, completos y sin alteraciones no autorizadas.
- **Disponibilidad:** la información y los sistemas están accesibles cuando se necesitan.

Una implementación adecuada de los controles de seguridad contribuye al cumplimiento normativo, asegura la continuidad del negocio y fortalece la protección de los activos organizacionales. Además, prepara a la organización para detectar, responder y gestionar incidentes de seguridad de forma oportuna (Cycognito, 2024).

1.1 Propósito de los controles de seguridad de la información

El objetivo principal de los controles de seguridad de la información es proteger los activos organizacionales frente a los diferentes riesgos y amenazas que puedan comprometer su disponibilidad, integridad y confidencialidad. En otras palabras, buscan garantizar que la información esté accesible cuando se necesita, confiable en su contenido y protegida frente a accesos no autorizados.

Estos controles permiten prevenir incidentes de seguridad, detectar anomalías en el funcionamiento de los sistemas y corregir vulnerabilidades antes de que generen un impacto mayor. Además, contribuyen a mantener la continuidad del negocio y a fortalecer la confianza de los clientes, empleados y socios estratégicos.

Implementar controles de seguridad no solo responde a la necesidad de mitigar ataques cibernéticos o accesos indebidos, sino también a cumplir con normas, leyes y estándares internacionales que regulan la protección de la información. Por ello, los controles representan un pilar fundamental de la gobernanza corporativa, ya que apoyan la toma de decisiones informadas, minimizan los impactos económicos y reputacionales y fomentan entornos tecnológicos seguros y resilientes.

Importancia de una implementación integral

Los controles de seguridad conforman un sistema integral de defensa que combina medidas técnicas, físicas y administrativas.

- Las medidas técnicas se relacionan con el uso de software, hardware y configuraciones seguras.
- Las medidas físicas incluyen la protección de equipos, instalaciones y accesos.
- Las medidas administrativas abarcan políticas, procedimientos y responsabilidades del personal.

Cuando estos elementos se implementan de manera coordinada, la organización puede reducir vulnerabilidades, responder de forma eficaz ante incidentes y cumplir con sus políticas internas y marcos regulatorios externos.

Fomento de la cultura de seguridad

El éxito de los controles no depende únicamente de la tecnología, sino también del compromiso de las personas. Su correcta aplicación contribuye a construir una cultura de seguridad que promueva la responsabilidad, la confianza y la mejora continua dentro de la organización.

En definitiva, los controles de seguridad de la información son herramientas estratégicas que permiten a las organizaciones mantener operaciones seguras, sostenibles y confiables en un entorno digital cada vez más cambiante y desafiante.

1.2 Tipos de controles

Los controles de seguridad de la información pueden clasificarse desde distintos enfoques, lo que facilita su comprensión y aplicación dentro de las organizaciones.

Una primera forma de clasificación se basa en la manera en que se implementan, distinguiéndose tres tipos principales:

- **Controles administrativos:** relacionados con políticas, procedimientos, normas y responsabilidades del personal.
- **Controles técnicos:** aplicados mediante software, hardware y configuraciones que protegen los sistemas informáticos.
- **Controles físicos:** orientados a la protección de instalaciones, equipos y accesos (Cycognito, 2024).

Otra forma de clasificar los controles se centra en su función dentro del marco de la gestión del riesgo, agrupándolos en:

- **Controles preventivos:** diseñados para evitar la ocurrencia de incidentes.
- **Controles detectivos:** orientados a identificar eventos o anomalías cuando se presentan.
- **Controles correctivos:** enfocados en mitigar los efectos y restablecer las condiciones normales tras un incidente (Equipo Auditoool, 2024).

Estas diferentes perspectivas permiten a las organizaciones diseñar un sistema integral de protección, capaz de reducir la probabilidad de incidentes y, al mismo tiempo, fortalecer su capacidad de respuesta y recuperación ante cualquier eventualidad. En un entorno digital dinámico, ninguna empresa está completamente exenta de riesgos, por lo que la combinación adecuada de controles se convierte en un componente esencial de la seguridad y la resiliencia organizacional.

A continuación, los tipos de controles de seguridad de la información:

- **Controles físicos**

Son medidas tangibles que resguardan las instalaciones y equipos frente a accesos no autorizados, robos o daños. Incluyen cerraduras, vallas,

biometría, vigilancia y guardias, así como sistemas de monitoreo ambiental que previenen riesgos por temperatura o humedad. Además, son clave en la continuidad operativa y la recuperación ante desastres, al proteger los sistemas de respaldo y la infraestructura crítica.

- **Controles técnicos**

Se apoyan en la tecnología para proteger sistemas y redes frente a ciberamenazas. Herramientas como firewalls, cifrado, antivirus, detección de intrusos y controles de acceso automatizan la defensa y mitigan vulnerabilidades. Su actualización constante y capacidad de adaptación los convierten en la primera línea de defensa frente a ataques sofisticados y cambios tecnológicos.

- **Controles administrativos**

Consisten en políticas, procedimientos y prácticas que estructuran la gestión de la seguridad de la información. A través de programas de capacitación, auditorías, gestión de accesos y evaluaciones de riesgo, orientan al personal y fortalecen la cultura de seguridad. También establecen roles y responsabilidades, reducen errores humanos y garantizan el cumplimiento normativo en la organización.

A continuación, se presentan ejemplos de controles de seguridad de la información aplicados en distintos contextos organizacionales. Estos casos ilustran cómo los controles físicos, técnicos y administrativos se adaptan a las necesidades y características de cada entorno.

Tabla 1. Ejemplos de tipos de controles en pymes

Tipo de control	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
Físicos	• Cerraduras y biometría en archivo clínico. • Cámaras de vigilancia en pasillos y acceso a urgencias. • Detectores de humo y extintores en áreas críticas. • Control de ingreso con carnet al personal y visitantes.	• Rejas y candados en salones de informática. • Control de acceso a la biblioteca con carnet estudiantil. • Cámaras de seguridad en pasillos. • Señalización y salidas de emergencia.	• Cercado perimetral de potreros y bodegas. • Candados en almacén de agroquímicos. • Cámaras de vigilancia en áreas de producción. • Sistemas de iluminación nocturna en accesos.
Técnicos	• Cifrado de historias clínicas digitales. • Firewall en la red hospitalaria. • Software antivirus actualizado en estaciones de trabajo. • Sistemas de respaldo automático de datos clínicos.	• Antivirus en computadores de docentes y administrativos. • Restricciones de acceso a internet por categorías. • Sistema de gestión académica con claves personalizadas. • Copias de seguridad de información académica.	• Sensores de riesgo automatizados con contraseñas seguras. • Control de acceso al software de inventario de cultivos. • Cámaras conectadas a la red para monitoreo remoto. • Respaldo digital de registros de producción.
Administrativos	• Protocolos de confidencialidad para personal de salud. • Políticas de seguridad y privacidad de datos de pacientes.	• Manual de uso responsable de equipos tecnológicos. • Políticas para el manejo de información estudiantil.	• Protocolos de ingreso y registro de trabajadores temporales. • Plan de respuesta ante emergencias agrícolas (plagas, incendios).

Tipo de control	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
	• Capacitación periódica en ciberseguridad. • Procedimientos de respuesta a incidentes de seguridad.	• Charlas de sensibilización sobre riesgos digitales. • Procedimientos para auditorías internas de seguridad.	• Capacitación en manejo seguro de agroquímicos. • Procedimientos de control de calidad y trazabilidad.

Nota: (IPS) Institución Prestadora de Servicios de Salud.

Para una mejor comprensión de su aplicación práctica, los controles de seguridad se agrupan en tres categorías funcionales: preventivos, detectivos y correctivos.

A continuación, se presentan los tipos de controles de seguridad de la información clasificados según su propósito operativo:

- **Controles preventivos**

Son medidas proactivas diseñadas para evitar que se materialicen errores, fraudes o incidentes antes de que ocurran. Se centran en reducir la probabilidad de riesgos mediante políticas claras, procesos bien estructurados y la capacitación del personal. Ejemplos de este tipo son la segregación de funciones, la restricción de accesos según roles, los programas de formación en normativas clave y las políticas de doble verificación en transacciones críticas. De esta forma, los controles preventivos actúan como una barrera inicial que fortalece la seguridad y la confiabilidad de las operaciones.

- **Controles detectivos**

Se enfocan en identificar irregularidades o problemas una vez que han ocurrido, proporcionando retroalimentación para evaluar la eficacia de los controles preventivos. Funcionan a través de mecanismos de supervisión, monitoreo y análisis que permiten descubrir anomalías en tiempo oportuno. Entre sus ejemplos destacan las conciliaciones periódicas de cuentas, las alertas automáticas en sistemas empresariales, el monitoreo en tiempo real y los análisis comparativos de variaciones financieras. Con ello, los controles detectivos ayudan a reducir el impacto de los incidentes al descubrirlos rápidamente.

- **Controles correctivos**

Tienen como finalidad solucionar los problemas detectados y asegurar que no vuelvan a repetirse. Estas medidas actúan después de la detección de un incidente, combinando respuestas inmediatas con ajustes permanentes en los procesos. Algunos ejemplos son la corrección de errores financieros, la actualización de políticas internas, la capacitación adicional del personal y el rediseño de procedimientos críticos. Así, los controles correctivos no solo mitigan daños, sino que también impulsan la mejora continua en la gestión del riesgo y la seguridad organizacional.

Tabla 2. Ejemplos de controles en pymes (preventivos, detectivos y correctivos)

Tipo de control	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
Preventivos	• Segregación de funciones en facturación y pagos.	• Control de accesos a laboratorios de	• Restricción de acceso a bodegas de insumos agrícolas.

Tipo de control	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
	• Restricción de accesos a historias clínicas con autenticación multifactorial. • Programas de capacitación en protección de datos de pacientes. • Políticas de doble verificación en compras.	informática solo para estudiantes autorizados. • Charlas preventivas sobre uso responsable de dispositivos. • Políticas de verificación de notas antes de su publicación. • Capacitación docente en prevención del fraude académico.	• Programas de formación en bioseguridad. • Políticas de control de insumos antes de la siembra.
Detectivos	• Conciliación periódica de cuentas de proveedores. • Alertas automáticas en el sistema ERP para detectar compras inusuales. • Auditorías internas de cumplimiento normativo.	• Revisión periódica de calificaciones frente a actas oficiales. • Alertas del sistema académico para detectar plagio en trabajos. • Supervisión de asistencia mediante listas digitales.	• Monitoreo de consumo de agua en sistemas de riego. • Revisión mensual de inventarios de insumos agrícolas. • Alertas en software de gestión para identificar pérdidas de producción. • Auditorías sobre registros de ventas.
Correctivos	• Ajuste de procesos administrativos tras detectar errores de facturación. • Actualización de protocolos de confidencialidad. • Capacitación adicional en áreas con incumplimientos.	• Modificación de manuales de convivencia tras detectar incidentes disciplinarios. • Reentrenamiento docente en áreas con debilidades pedagógicas.	• Rediseño de rutas de transporte tras detectar retrasos en entregas. • Actualización de protocolos de control de plagas. • Reentrenamiento de trabajadores en uso de maquinaria.

Tipo de control	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
		• Corrección de errores en bases de datos académicas.	

Nota: ERP son las siglas de (Enterprise Resource Planning).

La organización no debe limitarse a seleccionar una sola tipología de controles, ya que cada enfoque aporta un valor específico a la seguridad de la información. Lo más recomendable es combinarlos de manera estratégica, como quien conforma un equipo eficaz: algunos previenen, otros detectan y otros corrigen; mientras que los controles físicos, técnicos y administrativos se integran para cerrar posibles brechas. De esta forma, se establece un sistema de protección más completo, confiable y adaptable a las necesidades reales de la empresa, reduciendo riesgos innecesarios y garantizando la continuidad de las operaciones.

1.3 Normativa legal

Para implementar un plan eficaz de seguridad de la información, las organizaciones deben apoyarse en marcos normativos que sirvan como guía para la aplicación de controles de manera estructurada y coherente. Estos marcos, tanto de carácter internacional como nacional, ofrecen lineamientos y buenas prácticas que orientan la protección de los activos de información, permitiendo su adaptación a distintos sectores y contextos organizacionales.

A continuación, se presentan normas internacionales ampliamente reconocidas en materia de seguridad de la información; asimismo, se incluyen normativas nacionales que responden a las particularidades del entorno colombiano. Su conocimiento y correcta aplicación fortalecen la gestión institucional, promueven el

cumplimiento regulatorio y contribuyen al desarrollo de una cultura organizacional orientada a la protección de la información.

Tabla 3. Normativa internacional con aplicación en controles de seguridad

Norma / regulación	Enfoque principal	Aplicación en controles de seguridad	Ejemplo en pyme
ISO/IEC 27001	Sistema de Gestión de Seguridad de la Información (SGSI).	Define cómo implementar, monitorear y mejorar controles para garantizar confidencialidad, integridad y disponibilidad.	La empresa define un plan de copias de seguridad semanales, restringe accesos con usuarios y contraseñas únicas, y crea un procedimiento de recuperación de datos en caso de fallas del sistema.
ISO/IEC 27002	Buenas prácticas y catálogo de controles de seguridad.	Proporciona una guía detallada para seleccionar y aplicar controles administrativos, técnicos y físicos.	La empresa aplica autenticación de doble factor en correos, instala cámaras en la oficina y capacita trimestralmente a los empleados sobre phishing y manejo seguro de documentos.
NIST SP 800-53 (EE. UU.)	Controles de seguridad y privacidad para sistemas de información federales.	Ofrece un marco robusto de controles clasificándolos según impacto y criticidad, útil como referencia en distintos sectores.	La empresa aplica parches de seguridad mensuales (preventivo), monitoreo con Security Information and Event Management (SIEM) para detectar intrusiones (detectivo) y un plan de restauración de

Norma / regulación	Enfoque principal	Aplicación en controles de seguridad	Ejemplo en pyme
			servidores en la nube (correctivo).
(Control Objectives for Information and Related Technologies) COBIT	Gobernanza y gestión de TI.	Relaciona objetivos de negocio con la seguridad, orientando la implementación de controles desde la perspectiva de gobierno.	La empresa implementa control de acceso a la base de datos de clientes (técnico), revisiones periódicas de seguridad por auditor interno (administrativo) y cámaras en áreas críticas (físico), todo documentado para mostrar cumplimiento ante socios e inversionistas.

Nota: (TI) Tecnologías de la Información.

Tabla 4. Normativa nacional con aplicación en controles de seguridad

Norma / regulación	Enfoque principal	Aplicación en controles de seguridad	Ejemplo en pyme
Ley 1581 de 2012	Protección de datos personales.	Exige controles administrativos y técnicos que garanticen el tratamiento seguro de datos sensibles de los ciudadanos.	La IPS guarda historias clínicas en un sistema con claves únicas y solicita autorización escrita a los pacientes para el uso de sus datos.
Decreto 1377 de 2013	Reglamenta la Ley 1581, especificando condiciones de autorización y responsabilidad.	Refuerza controles para la autorización, uso y almacenamiento de información personal.	La empresa notifica a sus clientes por correo electrónico cómo usará sus datos y conserva el registro de aceptación.

Norma / regulación	Enfoque principal	Aplicación en controles de seguridad	Ejemplo en pyme
Ley 1273 de 2009	Delitos informáticos y protección de la información y de los datos.	Obliga a implementar controles que prevengan accesos no autorizados, fraudes y daños a sistemas informáticos.	La empresa implementa firewalls, antivirus, monitoreo de accesos y políticas de sanciones internas para prevenir fraudes en su plataforma.
Circular Externa 007 de 2018 (Superfinanciera)	Lineamientos de ciberseguridad para el sector financiero.	Obliga a entidades financieras a contar con planes de gestión de riesgos, monitoreo y respuesta ante incidentes.	La empresa designa a un responsable de ciberseguridad habilita autenticación multifactorial en accesos críticos, realiza copias de seguridad y pruebas de recuperación trimestrales; además documenta procedimientos de notificación a clientes y mantiene evidencia para auditoría.

1.4 Relación con activos y riesgos

Es fundamental tener presente que los controles de seguridad deben diseñarse y aplicarse de acuerdo con los activos de información, los cuales comprenden los datos, los sistemas, la infraestructura física y tecnológica, así como los procesos organizacionales. Cada uno de estos activos posee un valor específico para la empresa, por lo que resulta indispensable implementar medidas de seguridad adecuadas que garanticen su protección y eviten su pérdida, daño o acceso no autorizado.

Asimismo, los riesgos surgen a partir de amenazas y vulnerabilidades que pueden comprometer la disponibilidad, integridad o confidencialidad de dichos activos. Los controles tienen como propósito reducir la probabilidad de que un riesgo se materialice o, en su defecto, mitigar su impacto en caso de que ocurra.

En este sentido, la relación entre activos, riesgos y controles es inseparable. Generalmente, se sigue esta secuencia para asegurar una gestión eficaz de la seguridad de la información dentro de la organización:

Figura 1. Secuencia de gestión de la seguridad



Seguir esta planificación permite garantizar que las medidas de seguridad no se apliquen de forma genérica, sino que estén alineadas con las prioridades estratégicas de la organización y con su realidad operativa.

1.5 Criterios de selección

La selección de controles de seguridad requiere un enfoque estructurado y basado en los riesgos previamente identificados. Por ejemplo, según la norma ISO/IEC 27001, las organizaciones deben elegir los controles del anexo A en función de los resultados obtenidos en la evaluación de riesgos, asegurando que cada decisión quede documentada en la Declaración de Aplicabilidad (Secureframe, 2022).

De igual manera, el Marco de Gestión de Riesgos (RMF) del Instituto Nacional de Estándares y Tecnología (NIST) establece la fase select, en la cual se seleccionan, adaptan y documentan los controles necesarios conforme al nivel de impacto del sistema y a los resultados del análisis de riesgos (CMS, 2024).

Con base en estas guías, es posible identificar criterios clave que orientan la selección de los controles más adecuados para cada contexto organizacional.

Tabla 5. Lista sugerida de criterios

Criterio	Descripción	Ejemplo
Relevancia frente al riesgo	Los controles deben responder directamente a los riesgos identificados en el análisis, priorizando los activos críticos (información de clientes, sistemas financieros, etc.). La finalidad es garantizar la protección de la confidencialidad, integridad y disponibilidad.	Una empresa de comercio electrónico prioriza implementar autenticación multifactorial (MFA) en su sistema de pagos porque el análisis de riesgos mostró alta probabilidad de fraude.
Alineación con objetivos y normativas	Los controles deben ser seleccionados considerando tanto los objetivos de seguridad de la empresa como los requisitos regulatorios o legales que le aplicuen.	Una entidad financiera adopta cifrado de datos sensibles para cumplir con la Circular Externa 007 de 2018 de la Superfinanciera y a la vez garantizar confianza en sus clientes.
Proporcionalidad (costo - beneficio)	La implementación de controles debe ser proporcional al nivel de riesgo y a la capacidad financiera y técnica de la organización. No siempre	Una empresa de diseño gráfico decide usar un servicio en la nube con copias de seguridad automáticas en lugar de montar un costoso centro de datos propio.

Criterio	Descripción	Ejemplo
	es viable aplicar la solución más costosa, sino la más adecuada.	
Documentación justificativa	La selección (o exclusión) de cada control debe estar documentada en la Declaración de Aplicabilidad, donde se justifica con base en riesgos, normativas y recursos disponibles.	Una empresa de alimentos documenta por qué implementó control de accesos físicos a su bodega (por riesgo alto de robo) pero descartó la instalación de biometría (por costo elevado).
Adaptabilidad y mejora continua	Los controles deben poder ajustarse a los cambios en los riesgos, en la infraestructura tecnológica y en el contexto de la organización. Es un proceso dinámico, no estático.	Una empresa que comenzó usando contraseñas simples evoluciona a políticas de contraseñas robustas y luego a MFA, a medida que su volumen de clientes crece y el riesgo aumenta.

2. Implementación de controles

La implementación de controles de seguridad corresponde a la etapa en la que las políticas y planes definidos por la organización se traducen en acciones concretas dentro de la gestión de la seguridad de la información. De acuerdo con la norma ISO/IEC 27001, en esta fase se seleccionan, adaptan y aplican los controles necesarios para mitigar los riesgos identificados, asegurando que cada medida esté alineada con los objetivos estratégicos y operativos de la empresa.

2.1 Criterio de priorización

La priorización de controles y acciones correctivas consiste en organizar los riesgos identificados en la empresa con el fin de determinar cuáles deben abordarse primero. Este proceso permite orientar los esfuerzos y recursos hacia aquellas áreas donde la reducción del riesgo sea más significativa. Así, la organización puede centrarse en las vulnerabilidades con mayor probabilidad de explotación o con un impacto más alto sobre los activos críticos (PENTERA, 2024).

Para ello, quienes realizan el análisis consideran diversos factores al momento de establecer las prioridades y decidir a qué riesgos se les aplicarán los controles, entre los cuales se destacan los siguientes:

- **Probabilidad**

Hace referencia a la posibilidad de que la empresa sufra un ataque o incidente de seguridad, considerando factores como la exposición, las vulnerabilidades existentes y la capacidad de los atacantes.

- **Impacto**

Corresponde a las consecuencias que podría generar un evento adverso sobre la organización, afectando su operación, reputación o recursos económicos.

- **Valor del activo**

Evalúa la relevancia estratégica de los datos, sistemas o infraestructuras que podrían verse comprometidos ante un incidente, teniendo en cuenta su aporte a los objetivos del negocio.

- **Costo de mitigación**

Representa la inversión necesaria (en dinero, tiempo y recursos humanos) para implementar acciones que reduzcan o controlen los riesgos identificados.

- **Cumplimiento normativo**

Analiza el grado de exposición a sanciones o incumplimientos legales y regulatorios en caso de que los riesgos no sean gestionados de manera adecuada.

Después del proceso de evaluación, los riesgos pueden clasificarse según su nivel de prioridad. Generalmente, se organizan en cuatro categorías: crítico, alto, medio y bajo; sin embargo, algunas organizaciones prefieren utilizar un esquema simplificado de tres niveles (alto, medio y bajo), de acuerdo con sus necesidades, recursos y criterios internos de gestión.

- **Riesgos críticos**

Tienen una alta probabilidad de ocurrencia y un impacto severo. Pueden provocar la pérdida de información vital, la caída total de la red o la

interrupción completa de las operaciones. Requieren atención inmediata y una respuesta prioritaria.

- **Riesgos altos**

Combinan una probabilidad media o alta con un impacto significativo.

Afectan activos de gran valor y pueden generar interrupciones relevantes en los procesos. Demandan soluciones rápidas y efectivas.

- **Riesgos medios**

No representan una amenaza inmediata para los activos esenciales, pero si no se controlan, pueden agravarse con el tiempo. Ejemplo: detección temprana de virus o accesos no autorizados a datos de baja sensibilidad.

- **Riesgos bajos**

Presentan baja probabilidad e impacto mínimo. Incluyen vulnerabilidades menores, como fallos de software o intentos de phishing. Se gestionan mediante medidas preventivas, como parches de seguridad y monitoreo continuo.

Es importante tener en cuenta que la priorización presenta ciertas limitaciones. Entre ellas se encuentran la complejidad de los entornos interconectados, la subjetividad en la valoración humana, las restricciones de recursos y la constante evolución de las amenazas. Por lo tanto, este proceso debe ser dinámico y revisarse y ajustarse continuamente, de acuerdo con la periodicidad establecida por las directivas de la empresa (PENTERA, 2024).

2.2 Proceso de implementación de controles

En la implementación de controles, no basta con definir cuáles se aplicarán, sino que es clave establecer un proceso práctico que facilite su ejecución, de forma sencilla y

repetible, entonces para que las cosas no se queden en teoría, hay que trabajar desde la identificación de hallazgos hasta la definición de acciones concretas, garantizando que los recursos utilizados se puedan usar de forma eficiente y que las decisiones tomadas se hagan con base en los objetivos de la organización. Una forma en que se puede plantear es la siguiente:

Figura 2. Proceso de la implementación



Donde cada uno de estos pasos representa:

- **Recolección y consolidación**

Registrar hallazgos (vulnerabilidades, exposiciones, incidentes) y asociarlos con los activos afectados.

- **Evaluación de factores**

Calificar probabilidad, impacto y valor del activo; incluir costos de mitigación y requisitos regulatorios.

- **Cálculo y priorización**

Generar puntuación de riesgo (por ejemplo: probabilidad $\times$ impacto), ordenar riesgos y ajustar según costos y viabilidad operativa.

- **Clasificación**

Ubicar cada riesgo en niveles: crítico, alto, medio o bajo; asignar tiempos objetivo de acción: inmediato, 30 días, 90 días o monitoreo continuo.

- **Planificación de la respuesta**

Definir acciones específicas (parche, ajuste de configuración, control compensatorio, monitoreo) y asignar responsables y recursos.

- **Monitoreo y re - evaluación**

Revisar y actualizar la priorización periódicamente o ante cambios en el entorno o detección de nuevos riesgos.

2.3 Roles y responsabilidades en seguridad de la información

La cláusula 5.3 de la norma ISO/IEC 27001 establece que la alta dirección debe definir y asignar los roles, responsabilidades y autoridades relacionadas con la seguridad de la información, asegurando que dicha asignación quede debidamente documentada y comunicada a toda la organización (Holloway, 2025a).

Complementariamente, el anexo A, control A.5.2 de la norma ISO/IEC 27001:2022, indica que todos los empleados deben comprender y asumir responsabilidades específicas en materia de seguridad. Esto incluye a los propietarios de activos, quienes son responsables de su protección diaria (Holloway, 2025b).

A continuación, se presentan ejemplos de roles y responsabilidades para mayor claridad:

- **Alta dirección / gerente general:** aprueba políticas, garantiza el compromiso con la seguridad y asigna los recursos necesarios.
- **Responsable o líder de seguridad (CISO o similar):** diseña y supervisa los controles adecuados, coordina su implementación, evalúa la efectividad de los controles, supervisa los riesgos y lidera las auditorías.
- **Propietarios de activos:** se encargan del uso correcto y de la protección de activos específicos, como datos, sistemas e infraestructura.

- **Usuarios y empleados en general:** cumplen con las políticas y medidas de seguridad, actúan como primera línea de defensa, reportan incidentes y siguen los protocolos establecidos.
- **Audidores internos y externos:** verifican el cumplimiento de controles, políticas y procedimientos; identifican brechas de seguridad y recomiendan mejoras basadas en sus hallazgos.

Tabla 6. Lista sugerida de roles

Rol / responsable	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
Alta dirección / gerencia	Gerente aprueba presupuesto para firewall y capacitación en ciberseguridad.	Rector autoriza la compra de software educativo con licencias seguras.	Administrador asigna recursos para implementar cámaras de seguridad en la bodega.
Responsable de seguridad (CISO o designado)	Coordinador de TI gestiona copias de seguridad de historias clínicas y revisa accesos a la red.	Profesor de informática lidera políticas de uso de equipos y contraseñas seguras.	Ingeniero agrónomo implementa software de control de inventario con accesos diferenciados.
Propietarios de activos	Jefe de archivo clínico custodia las historias físicas y controla acceso restringido.	Bibliotecario se responsabiliza de la seguridad de los sistemas de gestión bibliotecaria.	Encargado de bodega custodia agroquímicos con inventario controlado y acceso restringido.
Usuarios / empleados	Enfermeros usan contraseñas únicas para acceso a historiales y reportan intentos de acceso no autorizado.	Docentes aplican políticas de uso responsable de internet y reportan incidentes de phishing.	Trabajadores siguen protocolos de bioseguridad y notifican pérdidas o daños en equipos de riego.

Rol / responsable	IPS ManoSana	Escuela Armando López Sierra	Finca La Costa
Auditores internos / externos	Auditoría interna revisa acceso al sistema de historias clínicas y cumplimiento de confidencialidad.	Auditor educativo verifica seguridad en los sistemas de notas y asistencia.	Auditor agrícola revisa registros de producción y trazabilidad frente a riesgos de manipulación de datos.

Las grandes empresas, que cuentan con departamentos especializados en seguridad de la información o ciberseguridad y con recursos económicos suficientes, suelen disponer de una estructura de roles claramente definidos. Cada perfil cumple funciones específicas que, en conjunto, aseguran la protección estratégica, técnica y operativa de la organización frente a amenazas digitales.

En contraste, las pequeñas empresas enfrentan mayores dificultades para implementar estos roles, debido a la inversión significativa que requieren en personal e infraestructura tecnológica. Por esta razón, a menudo deben gestionar la seguridad utilizando el talento disponible, incluso cuando los empleados no fueron contratados originalmente para estas funciones. A continuación, se presenta un listado de los principales perfiles especializados en ciberseguridad, indicando, cuando aplica, la sigla y el nombre completo del cargo, junto con una breve descripción de sus funciones (Arias, 2024).

Tabla 7. Lista de roles oficiales en ciberseguridad

Rol	Descripción
CISO (Chief Information Security Officer)	Responsable máximo de la estrategia de ciberseguridad, desde la planificación hasta la supervisión, reportando a la dirección.

Rol	Descripción
CSO (Chief Security Officer)	Encargado de la seguridad integral, incluyendo continuidad del negocio y recuperación ante desastres.
CTO (Chief Technology Officer)	Responsable de la implementación de nuevas tecnologías, en coordinación con el CISO para garantizar su seguridad.
CIO (Chief Information Officer)	Director de TI, asegura que la tecnología esté alineada con los objetivos de la organización.
DPO (Data Protection Officer)	Garantiza el cumplimiento legal en materia de protección de datos, impulsando una cultura de privacidad.
Arquitecto de ciberseguridad	Diseña estructuras de seguridad avanzadas, anticipando posibles ataques el pensar como un ciberdelincuente.
Analista de seguridad	Supervisa la implementación y eficacia de controles de seguridad en sistemas y servicios nuevos.
Informático forense	Investiga incidentes, identifica causas y preserva evidencia digital para análisis y procesos legales.
Hacker ético	Localiza fallos de seguridad mediante pruebas controladas y propone soluciones para fortalecer la infraestructura.

3. Monitoreo y verificación

Realizar un monitoreo adecuado y mantener procesos de verificación permanentes asegura que los controles de seguridad de la información no se limiten a un requisito documental, sino que se traduzcan en prácticas efectivas y confiables. El seguimiento constante permite detectar fallos en los sistemas y en las estrategias implementadas, así como evaluar el desempeño de los controles y verificar el cumplimiento de las normativas vigentes. De este modo, se fortalece la confianza de usuarios, clientes y aliados en la organización y se garantiza una gestión de seguridad más sólida y proactiva.

3.1 Importancia de la supervisión y validación de la seguridad de la información

La **supervisión constante** es fundamental para la seguridad de la información, ya que permite monitorear de manera continua la actividad de los sistemas y de los controles implementados.

Esta observación ayuda a identificar comportamientos inusuales, intentos de acceso no autorizados, fallos de configuración y vulnerabilidades explotables. Además, proporciona datos valiosos para medir el desempeño de los controles y ajustarlos conforme a la estrategia de seguridad, anticipándose a posibles incidentes y convirtiendo la gestión en un proceso proactivo en lugar de reactivo.

La **validación o verificación** complementa este proceso, asegurando que los controles funcionen según su diseño y objetivos. Esto puede realizarse mediante revisiones periódicas, auditorías internas y externas, pruebas de cumplimiento normativo y evaluaciones de desempeño. Gracias a la verificación, se identifican brechas de seguridad, se corrigen desviaciones y se garantiza la alineación con marcos

regulatorios y estándares internacionales, fortaleciendo la **confiabilidad, transparencia y credibilidad** de la organización.

Cuando se integran **monitoreo y verificación**, se forma un ciclo de mejora continua: la supervisión detecta riesgos en tiempo real, mientras que la verificación garantiza la efectividad de las acciones tomadas. De este modo, la seguridad de la información deja de ser un requisito formal para convertirse en una práctica activa, confiable y en constante perfeccionamiento, protegiendo tanto a la organización como a sus partes interesadas.

3.2 Estrategias de seguimiento

Los controles de seguridad requieren un seguimiento sistemático, constante y orientado a resultados. No basta con implementarlos; es fundamental verificar regularmente su funcionamiento y efectividad en la práctica. Para facilitar su aplicación, a continuación, se presentan algunas estrategias de seguimiento que las organizaciones pueden implementar de manera práctica, sin necesidad de invertir esfuerzos desproporcionados:

Tabla 8. Estrategias de seguimiento de los controles de seguridad de la información

Estrategia de seguimiento	Descripción	Ejemplos
Revisión del diseño y aplicación	Consiste en analizar si el control de seguridad fue diseñado de manera adecuada para mitigar el riesgo identificado y, además, comprobar que se está aplicando en la práctica.	a) La empresa establece doble autenticación para correos corporativos y se verifica si todos los usuarios realmente la tienen activa. b) Se diseña un protocolo de ingreso a bodega con carnet, y se revisa si los trabajadores lo cumplen en la operación diaria.

Estrategia de seguimiento	Descripción	Ejemplos
Medición de la eficacia del control	Se centra en determinar si el control cumple con su propósito de prevenir, detectar o corregir riesgos. Esto implica medir resultados frente a los objetivos esperados.	a) Un sistema de videovigilancia se evalúa según la cantidad de incidentes resueltos gracias a las grabaciones. b) El antivirus se mide por la detección y bloqueo de intentos de malware en un mes.
Periodicidad de revisión	Establece la frecuencia con que se revisan los controles, priorizando aquellos más críticos o expuestos. La periodicidad depende del nivel de riesgo y del impacto esperado.	a) Las copias de seguridad críticas se revisan semanalmente, mientras que las políticas de acceso a internet se revisan cada seis meses. b) La configuración de firewalls se audita mensualmente, pero el plan de respuesta a incidentes se revisa anualmente.
Uso de indicadores clave (KCI)	Implica definir métricas que permitan monitorear objetivamente el desempeño de los controles. Los indicadores se alinean con los objetivos de seguridad de la organización.	a) Número de intentos fallidos de inicio de sesión en el sistema de facturación. b) Porcentaje de respaldos completados con éxito frente al total planificado en el mes.
Registro y retroalimentación	Supone documentar hallazgos, conservar evidencias y generar planes de mejora continua. Facilita auditorías internas y la trazabilidad de decisiones en seguridad.	a) Durante una revisión se detecta que el 20 % de los equipos no recibió la última actualización, se documenta y se establece un plan de corrección. b) Una auditoría interna identifica brechas en la política de uso de contraseñas y se recomienda capacitación al personal.

3.3 Periodicidad

En los controles de seguridad, la periodicidad se refiere a la frecuencia con la que deben revisarse para verificar su funcionamiento y correcta aplicación. No todos los controles requieren el mismo ritmo de monitoreo; este depende del nivel de riesgo, las exigencias normativas y los recursos disponibles en la organización. Los riesgos más críticos necesitan revisiones más frecuentes (por ejemplo, diarias o semanales), mientras que los de menor relevancia pueden evaluarse en intervalos más amplios (mensuales, trimestrales o anuales). Con base en los riesgos identificados, la empresa puede diseñar un plan de revisión de controles con la periodicidad adecuada, asegurando así la efectividad y los mejores resultados de las medidas implementadas.

Tabla 9. Periodicidad sugerida según el nivel de riesgo

Nivel de riesgo	Periodicidad sugerida	Justificación	Ejemplos de aplicación
Crítico	Diaria o semanal.	Los activos críticos suelen ser objetivos prioritarios de atacantes. La alta frecuencia garantiza detección temprana de incidentes y reacción inmediata.	• Monitoreo de accesos a sistemas financieros. • Revisión de alertas en firewalls y sistemas de detección de intrusos.
Alto	Quincenal o mensual.	Son sistemas relevantes para la continuidad del negocio. Aunque el riesgo no es tan urgente como en los críticos, un fallo puede generar pérdidas económicas y reputacionales importantes.	• Validación de copias de seguridad. • Verificación de parches en sistemas de gestión empresarial (ERP, CRM).
Medio	Trimestral.	Son riesgos con impacto moderado, que pueden controlarse con revisiones periódicas. La frecuencia	• Revisión de permisos de usuarios en aplicaciones internas.

Nivel de riesgo	Periodicidad sugerida	Justificación	Ejemplos de aplicación
		trimestral equilibra esfuerzo y seguridad.	• Evaluación de políticas de contraseñas en estaciones de trabajo.
Bajo	Semestral o anual.	Los controles de bajo riesgo tienen poco impacto en caso de falla. Una revisión menos frecuente optimiza recursos sin comprometer la seguridad global.	• Inspección física de archivos almacenados en bodegas. • Verificación de equipos en desuso conectados a la red.

3.4 Registros y evidencias

Los registros y evidencias son documentos, archivos o reportes que demuestran de manera objetiva que el monitoreo y la verificación de los controles se han realizado según lo planificado. Estos elementos no solo facilitan auditorías internas y externas, sino que también permiten identificar patrones de incidentes, mejorar continuamente los procesos y asegurar el cumplimiento de normativas nacionales e internacionales aplicables.

Un registro bien gestionado debe incluir: fecha, responsable, control verificado, hallazgos, acciones tomadas y resultado final, además de cualquier información adicional que la empresa considere relevante. Es fundamental que estos registros se mantengan organizados, seguros y accesibles únicamente para las partes autorizadas.

A continuación, se presentan algunos tipos de registros y evidencias utilizados comúnmente:

Tabla 10. Tipos de registros y evidencias

Tipo de registro / evidencia	Descripción	Ejemplo
Bitácoras de eventos (logs)	Archivos generados por sistemas y aplicaciones que registran actividades como accesos, cambios o intentos de intrusión.	Log del firewall mostrando intentos de corrección bloqueados en la última semana.
Informes de monitoreo	Reportes periódicos que documentan el estado de los controles y su desempeño.	Informe mensual de cumplimiento de parches de software.
Actas de verificación	Documentos que certifican que se realizaron controles específicos en una fecha determinada.	Acta de revisión trimestral de respaldos de información firmada por el responsable de TI.
Registros de incidentes	Documentación de eventos de seguridad, análisis de causa raíz y medidas correctivas implementadas.	Registro de un ataque de phishing detectado, con acciones de bloqueo y capacitación posterior.
Evidencias gráficas o capturas	Pruebas visuales (screenshots, fotos) que demuestran la existencia y correcto funcionamiento de controles.	Captura de pantalla del antivirus mostrando la última actualización aplicada.
Listas de chequeo de auditoría	Listas de verificación utilizadas para confirmar el cumplimiento de procedimientos de seguridad.	Lista de chequeo completada de la inspección física de servidores en el data center.

Como recomendación, los registros deben mantenerse organizados en repositorios seguros, ya sea de forma digital o física, siendo útiles los sistemas de gestión documental que muchas empresas implementan actualmente. El tiempo de

retención de estos registros debe definirse según la política interna y los requisitos regulatorios aplicables. De esta manera se asegura la trazabilidad y disponibilidad de la información para futuras auditorías y revisiones.

Tabla 11. Formato de registro de monitoreo de controles de seguridad

Campo	Descripción / instrucción de llenado	Ejemplo de diligenciamiento
Fecha de monitoreo	Día en que se realizó la actividad de monitoreo.	08/09/2025.
Área / activo monitoreado	Especificar el área, sistema, servidor o proceso que se está revisando.	Servidor de archivos - carpeta de proyectos.
Control evaluado	Describir brevemente el control de seguridad revisado.	Control de acceso a carpetas compartidas.
Responsable	Nombre y cargo de quien realizó el monitoreo.	Juan Pérez - analista de TI.
Hallazgos	Detallar si el control está funcionando, si hay incidentes detectados o desviaciones.	2 accesos no autorizados detectados en el log.
Acciones tomadas	Describir las medidas correctivas o preventivas aplicadas.	Bloqueo de usuarios sospechosos y notificación a dirección.
Resultado final	Indicar si el control queda en estado conforme o requiere seguimiento adicional.	Conforme - se programó revisión adicional en 7 días.
Evidencia adjunta	Indicar si se adjunta soporte (captura de pantalla, informe, log).	Captura de pantalla del log adjunto al reporte digital.

Campo	Descripción / instrucción de llenado	Ejemplo de diligenciamiento
Firma o validación	Firma digital o física del responsable o del auditor.	Firma digital registrada en el sistema.

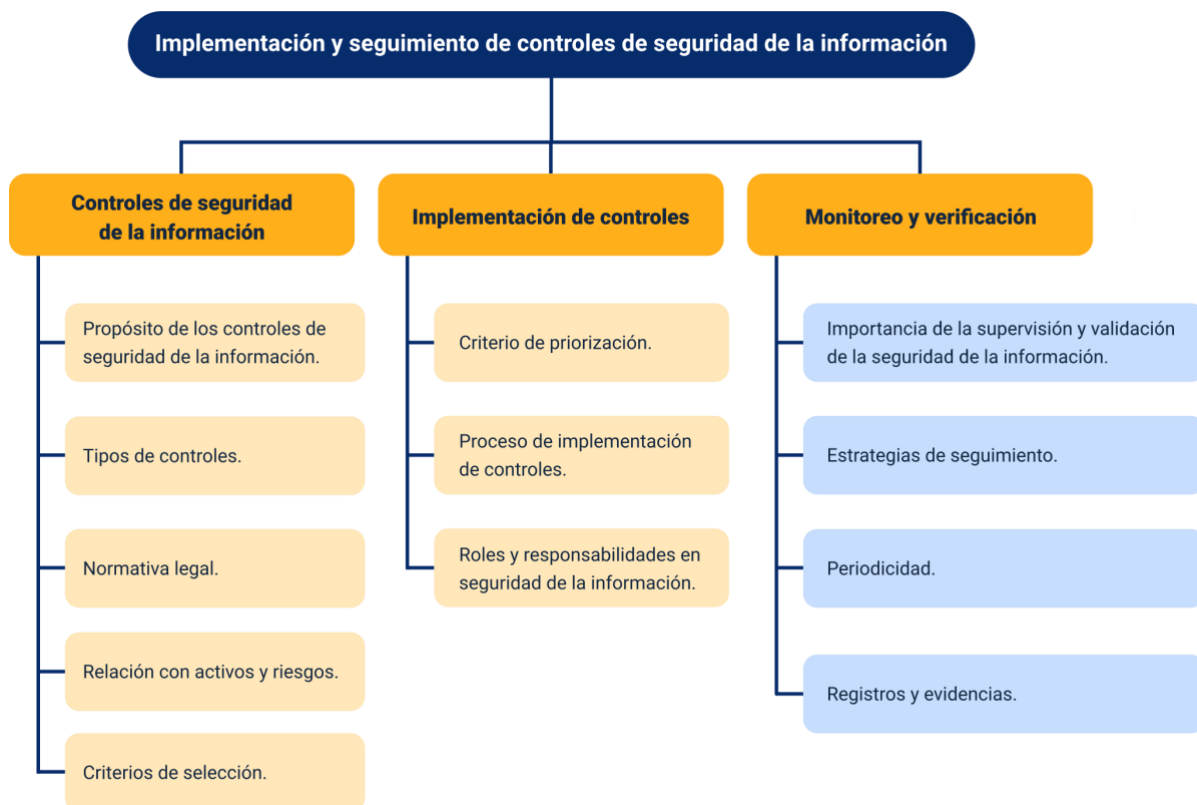
Otras recomendaciones a tener en cuenta con estos registros son:

- Los formatos pueden implementarse en Excel, Google Forms o mediante un software de gestión documental.
- Es recomendable mantener una numeración consecutiva de los registros para facilitar su trazabilidad.
- Siempre que sea posible, adjuntar evidencias (capturas de pantalla, archivos PDF, fotos u otros) que respalden la información reportada.

Síntesis

El componente formativo “Implementación y seguimiento de controles de seguridad de la información” tiene como propósito fortalecer las competencias necesarias para proteger los activos de información dentro de una organización. En primer lugar, aborda el estudio de los controles de seguridad de la información, destacando su propósito, los diferentes tipos existentes, la normativa legal que los respalda, su relación con los activos y los riesgos, así como los criterios de selección que permiten definir cuáles son los más adecuados para cada contexto. Posteriormente, se profundiza en la implementación de controles, proceso que implica establecer criterios de priorización según el nivel de riesgo, definir los roles y responsabilidades del personal encargado y ejecutar las acciones técnicas y administrativas que garanticen su correcta aplicación.

Finalmente, se desarrolla la fase de monitoreo y verificación, orientada a supervisar y validar la efectividad de los controles mediante estrategias de seguimiento, la definición de periodicidades y la generación de registros y evidencias que respalden la gestión realizada. En conjunto, este componente promueve una visión integral de la seguridad de la información basada en la gestión del riesgo, el cumplimiento normativo y la mejora continua de los procesos organizacionales.



Material complementario

Tema	Referencia	Tipo de material	Enlace del recurso
Normativa legal	Dirección de Impuestos y Aduanas Nacionales. (2023). Gestión de Riesgos de Seguridad de la Información.	PDF	https://www.dian.gov.co/atencionciudadano/LMDP/Informacion-Innovacion-y-Tecnologia/Seguridad-de-la-Informacion/Cartillas/CT-IIT-0132.pdf
Normativa legal	Global Quality Corp. (2022). ISO 27001 Gestión de Riesgos de Seguridad de la Información en 3 minutos.	Video	https://www.youtube.com/watch?v=1i-J3FtJYQg
Implementación de controles	Soy Ingenio. (2021). ¿Qué es el CICLO PHVA o PDCA? Ejemplo personal. Deming.	Video	https://www.youtube.com/watch?v=kWp-WGSmV3U
Importancia de la supervisión y validación de la seguridad de la información	LATAM Certificaciones TI. (2025). CISO: Seguridad de la Información: Plan de Implementación de Controles y Política de Seguridad de TI.	Video	https://www.youtube.com/watch?v=O3I8FXam9FE
Implementación de controles	CyberAcademy51. (2024). 1.1.2 Tipos de controles de seguridad CompTIA Security+ SY0-701 explicado en Español.	Video	https://www.youtube.com/watch?v=u9j89nRbqU4
Implementación de controles	CyberAcademy51. (2024). 1.1.1 Categorías de controles de seguridad CompTIA Security+ SY0-701 explicado en Español.	Video	https://www.youtube.com/watch?v=NCa7gUBd4JA
Implementación de controles	LATAM Certificaciones TI. (2024). CISO: Ciberseguridad: SOC 2 - Guía completa de controles de seguridad.	Vídeo	https://www.youtube.com/watch?v=SlOqhCwOpRw

Glosario

Asignación de responsables: proceso mediante el cual se designan personas o equipos específicos para ejecutar, supervisar y mantener los controles de seguridad. Garantiza que haya claridad en las funciones y evita la duplicidad o ausencia de responsabilidades.

Auditoria: actividad sistemática, documentada e independiente para evaluar si los controles de seguridad están implementados correctamente y si cumplen con las políticas, normas y objetivos de la organización. Puede ser interna o externa.

CIA (Confidencialidad, Integridad, Disponibilidad): principios fundamentales de la seguridad de la información que aseguran que los datos sean accesibles solo por personas autorizadas, no sean alterados indebidamente y estén disponibles cuando se necesiten.

Controles de seguridad: son las medidas, técnicas, administrativas y físicas implementadas para proteger los activos de información. Su objetivo es prevenir incidentes, detectar irregularidades y mitigar impactos, asegurando la confidencialidad, integridad y disponibilidad de los datos.

Gestión de riesgos: conjunto de procesos que permite identificar, analizar, valorar, tratar y monitorear riesgos, con el fin de minimizar su impacto en la seguridad de la información y los objetivos organizacionales.

Indicadores de control: métricas utilizadas para medir el desempeño y la efectividad de los controles implementados. Permiten detectar fallas a tiempo y tomar decisiones de mejora con base en datos objetivos.

Mejora continua: enfoque de trabajo que busca optimizar los procesos y controles de forma permanente. Se apoya en el ciclo PHVA (Planear, Hacer, Verificar, Actuar) para adaptarse a nuevos riesgos y cambios en el entorno.

Mitigación: conjunto de acciones diseñadas para reducir la probabilidad o el impacto de un riesgo. Puede incluir ajustes en procesos, adquisición de tecnología o capacitación del personal.

Monitoreo: actividad de seguimiento permanente de los controles de seguridad y los eventos que puedan comprometer la información. Permite detectar anomalías y actuar de manera preventiva o correctiva.

Normativa: conjunto de leyes, estándares técnicos y buenas prácticas que orientan a las organizaciones en el diseño, implementación y cumplimiento de políticas de seguridad de la información.

Plan de acción: documento o conjunto de actividades planificadas para implementar mejoras, corregir fallas o atender riesgos. Incluye tiempos, responsables, recursos y metas específicas.

Prioridad: nivel de urgencia asignado a un riesgo o actividad de control, basado en su impacto, probabilidad y relevancia para los objetivos de la organización.

Riesgo: posibilidad de que una amenaza aproveche una vulnerabilidad para causar daño a los activos de información, afectando la confidencialidad, integridad o disponibilidad de los mismos. Su análisis permite tomar decisiones informadas.

Seguridad de la información: disciplina que implementa medidas para proteger los datos de una organización, garantizando que se mantengan confidenciales, íntegros y disponibles ante cualquier tipo de amenaza.

Valoración de riesgo: consiste en asignar un nivel de importancia o gravedad a los riesgos identificados, considerando su probabilidad y el impacto que tendrían sobre los activos. Esta valoración facilita priorizar acciones preventivas o correctivas para minimizar los efectos negativos sobre la organización.

Referencias bibliográficas

Arias, S. (2024). Estos son los principales roles en la ciberseguridad.

<https://www.arsys.es/blog/principales-roles-ciberseguridad>

CMS CyberGeek. (2024). CMS risk management framework (RMF): Select step.

<https://security.cms.gov/policy-guidance/cms-risk-management-framework-rmf-select-step>

Cycognito. (2024). What are security controls: Types, functions, and 8 frameworks to

know. CyCognito. <https://www.cycognito.com/learn/exposure-management/security-controls.php>

Equipo Auditool. (2024, noviembre 21). Control interno. Auditool.

<https://www.auditool.org/blog/control-interno/cual-es-la-diferencia-entre-controles-preventivos-detectivos-y-correctivos>

Holloway, D. (2025a). ISO 27001 requirement 5.3 – organisational roles &

responsibilities. ISMS.Online. <https://www.isms.online/iso-27001/organisational-roles-responsibilities-authorities/>

Holloway, D. (2025b). ISO 27001:2022 annex A 5.2 - information security roles and

responsibilities. ISMS.Online. [https://www.isms.online/iso-27001/annex-a-2022/5-2-information-security-roles-responsibilities-2022 /](https://www.isms.online/iso-27001/annex-a-2022/5-2-information-security-roles-responsibilities-2022/)

IBM. (2023). ¿Qué son los controles de seguridad? Ibm.com.

<https://www.ibm.com/mx-es/think/topics/security-controls>

PENTERA. (2024). Glossary Risk Prioritization. Pentera. [https://pentera.io/glossary/risk-](https://pentera.io/glossary/risk-prioritization/)

[prioritization/](https://pentera.io/glossary/risk-prioritization/)

Secureframe. (2022). ISO 27001 controls explained: A guide to Annex A (updated 2024).
<https://secureframe.com/hub/iso-27001/controls>

Créditos

Nombre	Cargo	Centro de Formación y Regional
Milady Tatiana Villamil Castellanos	Responsable del ecosistema	Dirección General
Claudia Johanna Gómez Pérez	Responsable de línea de producción	Centro Agroturístico - Regional Santander
Armando Javier López Sierra	Experto temático	Centro de Comercio y Servicios - Regional Tolima
Erika Fernanda Mejía Pinzón	Evaluadora para contenidos inclusivos y accesibles	Centro Agroturístico - Regional Santander
Jenny Rocio Reyes Acevedo	Diseñadora de contenidos	Centro Agroturístico - Regional Santander
Andrea Paola Botello De la Rosa	Desarrolladora full stack	Centro Agroturístico - Regional Santander
María Alejandra Vera Briceño	Animadora y productora audiovisual	Centro Agroturístico - Regional Santander
Yineth Ibette Gonzalez Quintero	Validadora y vinculadora de recursos educativos digitales	Centro Agroturístico - Regional Santander
Andrea Ardila Chaparro	Evaluadora para contenidos inclusivos y accesibles	Centro Agroturístico - Regional Santander